

Laboratorio No. 2

Parte I – Comprensión del ataque

1. Explique, con sus palabras, cómo se llevó a cabo el ataque.

Primeramente se inició la máquina virtual con Kali Linux, y se aprovecha que este ya trae instalada la herramienta "Set Tool Kit". Se ingresa a esta aplicación la cuál abre un menú en la consola y se selecciona el ataque de ingeniería social, después se despliega otro menú y en este se selecciona la opción 2, después muestra otro menú nuevamente ahora se selecciona la opción 3 y ya muestra un menú final en el cual se selecciona la opción 2 que dice "Site Cloner"; ahora pide una dirección donde se alojará el sitio clonado y después se ingresa la URL del sitio que se desea clonar. Entonces ya con el sitio clonado se hace uso de ingeniería social para que la víctima ingrese sus credenciales, al momento de que la víctima ingrese sus credenciales a el simplemente se le recargará la página pero esta vez ya en el sitio original y las credenciales ya le quedaron al atacante.

2. ¿Qué papel juega la ingeniería social en la efectividad del ataque?

La ingeniería social juega un papel importante ya que básicamente se encarga de engañar a la víctima y convencerla de que entre al enlace del sitio clonado y no del sitio original, pero esto puede llegar a ser relativamente más sencillo que por ejemplo tratar de explotar vulnerabilidades en sistemas operativos o tratar de evadir medidas de seguridad en algún sistema. Y más ahora en día donde las personas realizan casi todo por medio de sitios web, y muchas veces se peca de confiar demasiado, ya que se les puede enviar un enlace en WhatsApp por ejemplo y no se lo piensan y lo abren e ingresan sus credenciales y caen en ataques

3. ¿Qué características tenía el sitio clonado que hacían difícil distinguirlo del real?

Realmente era una copia exacta del sitio original, por lo que en general es muy difícil distinguirlo, esto si solo nos quedamos con la parte visual del sitio, pero donde es sencillo verificar es en la URL, ya que por ejemplo en este caso no es un enlace lo que vemos si no que nuestra dirección IP. Ahora de otra cosa que me di cuenta es que si en algunas sitios no se realiza la clonación tan precisa, ya que ciertos elementos como imágenes, botones o colores o no aparecen o aparecen en ubicaciones extrañas en la pantalla.

Parte II – Controles y medidas para prevenir ataques de tipo phishing

1. Controles técnicos que puede implementar una organización:

- *Autenticación multifactor (MFA): ¿Cómo reduce el riesgo aunque el atacante tenga la contraseña?*

Reduce en gran manera el riesgo, ya que se puede decir que con MFA se tiene otra capa de seguridad, entonces aunque tengan la contraseña aún faltaría un token, un pin o una validación que se envíe a otro correo, el punto es que para ingresar a lo que quieran no basta con la contraseña, esto hace más seguro el acceso y es una buena forma de evitar el phishing

- *Certificados SSL/TLS y navegación segura (https): ¿Qué debe observar el usuario?*

En algunos navegadores cuando se trata de un sitio seguro se muestra un candado en la barra de direcciones, si no fuera el caso también se puede verificar que al sitio que está ingresando inicie con "https://", ya que esto quiere decir que es un sitio con la conexión cifrada. Otra cosa a revisar es que el usuario debe conocer el sitio al que desea ingresar, es decir, si sabe que el sitio es "facebook.com" pero si el sitio en donde va a ingresar sus credenciales dice "facebo0k.com" quiere decir que se trata de un sitio que no es el oficial

- *Filtros anti-phishing en navegadores y correo electrónico*

Estos son de gran ayuda ya que previenen que se accedan a enlaces sospechosos y bloquean los correos que pueden llevar contenido malicioso

- *Uso de gestores de contraseñas que detectan URLs incorrectas*

Los gestores de contraseñas guardan credenciales asociadas a sitios específicos. Si el usuario intenta iniciar sesión en un sitio sospechoso con una URL diferente, el gestor no autocompletará los datos, entonces esto ya alerta al usuario de que no se encuentra en el sitio que cree que está

- *Configuración de alertas de inicio de sesión sospechoso*

Es importante habilitar esta opción que ya la traen varias aplicaciones, solo que muchas veces por desconocimiento no se activa. Lo que hace esta configuración básicamente es enviar una alerta cuando se detecta un inicio de sesión en determinada aplicación, la alerta muchas veces incluye la ubicación el nombre del equipo en donde se está iniciando la sesión, y si el usuario no es quien está iniciando sesión esta alerta le permite cerrar todas las sesiones o cambiar la contraseña

2. **Controles humanos (capacitación y cultura):**

- *Campañas de concienciación en ciberseguridad*

Son de ayuda para enseñar a los usuarios de cómo reconocer ataques de phishing, los riesgos de entrar a enlaces desconocidos, si se tiene conocimiento de los riesgos y todas la consecuencia que pueden haber se reduce la probabilidad de que los usuarios caigan en ataques o mínimamente que estén más alertas

- *Simulaciones de phishing periódicas*

Una simulación puede permitir una evaluación al usuario y ver si está preparado si lo intentan atacar, también ayuda a identificar debilidades y dar la retroalimentación necesaria sin consecuencias reales

- *Políticas de seguridad claras sobre no compartir credenciales*

Es muy importante que se haga de conocimiento de que las contraseñas y códigos no deben compartirse con nadie, ni siquiera con personal técnico. Esto para prevenir ataques que se hacen pasar como solicitudes reales que vienen del área de TI.

- *Capacitación para identificar sitios falsos*

Es muy importante que los usuarios sepan a que URL desean entrar, saber el nombre correcto y siempre ver la URL antes de ingresar datos, para verificar que sí sea el sitio en el que desean estar

3. **Controles organizacionales y administrativos:**

- *Políticas de respuesta ante incidentes de ingeniería social*

En las empresas siempre se debe tener un plan para prevenir, para detectar y para responder ante un ataque, esto puede ser informar a los de seguridad o aislar los equipos o sistemas que fueron vulnerados

- *Clasificación y control de acceso a datos sensibles*

A los colaboradores de la empresa solo se les debe dar acceso a la información necesaria para su trabajo, así en caso de se suceda un ataque el daño sea mínimo

- *Registros de auditoría y monitoreo continuo de accesos*

Llevar un registro detallado de los accesos y monitorear constantemente la actividad permite detectar comportamientos extraños, estos pueden ser accesos fuera del horario habitual o desde ubicaciones desconocidas

- *Procedimientos de verificación en soporte técnico*

Se tiene que tener un proceso exigente para poder verificar que si se trate de la persona que dice ser. Por ejemplo, si se solicita un cambio de contraseña primero verificar que si es algún colaborador de la empresa y no un atacante que solo está suplantando a otro

Parte III – Reflexión ética y profesional

1. **¿Por qué este tipo de conocimiento debe usarse con responsabilidad?**

El tener el conocimiento de esto permite anticiparse y estar preparado para este tipo de ataque, pero si se usa con malas intenciones puede permitir robar la identidad de otra personas, puede dar lugar a extorsiones y que realmente tampoco es tan complicado de hacer, entonces la tener el conocimiento de estas prácticas se adquiere la responsabilidad de usarlo para protegerse ante estos ataques y no de atacar

2. **¿Cuál es la diferencia entre un pentester ético y un ciberdelincuente?**

La diferencia básicamente es la intención, es decir, un pentester trabaja bajo una autorización del dueño del sistema, mientras que un ciberdelincuente actúa sin autorización de nadie y lo hace con malas intenciones, como lo puede ser robar, extorsionar o simplemente causar daño a terceros

3. **¿Qué consecuencias legales podría tener un ataque real de este tipo en Guatemala?**

En Guatemala no existe una ley que especifique o clasifique el phishing como un delito, pero las acciones que se relacionan a esta practica si pueden ser considerados como delitos, por ejemplo: estafa, fraude informática o robo de identidad

4. **¿Qué responsabilidad tienen los usuarios, las empresas y los profesionales de TI en la prevención del phishing?**

En el caso de los usuarios finales la responsabilidad está en mantenerse informados y tener conciencia de que un solo clic en un enlace o correo sospechoso pueden caer en un ataque; las empresas por su parte también tienen que proteger tanto sus datos como la de sus clientes y no tienen que pensar en la seguridad como un gasto si no como justo lo que es, un seguro que ayuda a prevenir problemas mayores; y TI por su parte se tiene la responsabilidad de anticiparse a amenazas e implementar controles, como también tiene que educar e instruir a una cultura de concientización de los riesgos y sobre todo las consecuencias que se tienen de un ataque